

Updated Security Standards (2025)

wiki/security/security-standards-2025 · Updated 2026-02-18 · Owner: Security

Purpose

This document sets out Northwind's updated security standards, effective 2025. It supersedes earlier guidance where the two conflict. It is maintained by the Security team and reflects current industry best practice.

Security standards evolve as research improves. The changes below bring Northwind in line with modern guidance and, in several cases, reduce friction for employees while improving real-world safety.

Guiding principles

- Prefer controls that work with human behaviour, not against it.
- Length and uniqueness beat complexity rules.
- Phishing-resistant factors beat shared secrets.
- Least privilege, reviewed regularly, limits the blast radius of any compromise.

Passwords

Following the updated NIST SP 800-63B guidance, Northwind no longer enforces periodic password rotation. Users are required to change a password only when there is evidence of compromise. Forced expiry has

been disabled in the identity provider.

- Minimum length is now at least 14 characters.
- Passphrases are strongly encouraged over complex but short passwords.
- We screen new passwords against known-breached password lists.
- Composition rules such as forced symbols are relaxed in favour of length.

Why rotation was removed

Mandatory periodic rotation pushed users toward predictable, incremented passwords and did not meaningfully reduce compromise. Modern guidance favours long, unique secrets that are only changed when there is a reason to. Removing forced expiry reduces password reuse and support load without weakening security.

Transition from the old policy

Where this document conflicts with the older password policy, this document wins. The identity provider has been reconfigured accordingly. Teams should update any local documentation that still references forced 90-day rotation.

Multi-factor authentication

A second factor is mandatory for all accounts, and a hardware second factor is strongly encouraged for privileged access.

- Phishing-resistant factors such as hardware security keys are preferred.
- SMS codes are permitted only as a last-resort backup.
- Privileged and administrative accounts must use a hardware key.

Privileged access

Administrative and production access carries extra requirements: a hardware key, access that is time-bound where possible, and quarterly review. Privileged sessions are logged.

Data protection

- Sensitive data must be encrypted in transit and at rest.
- Access to production data follows least privilege and is reviewed quarterly.
- Secrets are stored in Secret Manager, never in code or configuration files.
- Data is classified so that controls match sensitivity.

Data classification

Classify data as public, internal, confidential, or restricted, and apply controls to match. The higher the classification, the tighter the access and the more thorough the logging.

Device security

Company devices must have disk encryption enabled, automatic screen lock, and current operating-system updates. Lost or stolen devices must be reported to IT and Security immediately so access can be revoked.

Patching

Keep operating systems and key applications current. Many compromises exploit known vulnerabilities that a pending update would have closed. Do not defer security updates indefinitely.

Incident reporting

Report suspected security incidents to the Security team without delay. Early reporting is always better than waiting for certainty. There is no penalty for a good-faith report that turns out to be a false alarm.

Worked example

A team is building a new service that stores customer records. They classify the data as confidential, encrypt it in transit and at rest, store the database credentials in Secret Manager, grant production access only to the two engineers who need it, and schedule that access for quarterly review. They require a hardware key for the admin console. The service passes its security review on the first pass.

Frequently asked questions

Do I still have to change my password every quarter? No. Forced expiry has been disabled; change it only on evidence of compromise.

What is the minimum password length now? At least 14 characters, with passphrases encouraged.

Is SMS acceptable as a second factor? Only as a last-resort backup; prefer an authenticator app or a hardware key.

Common mistakes

- Treating the old 90-day rotation rule as still in force.
- Using a short, complex password instead of a long passphrase.
- Storing secrets in configuration files instead of Secret Manager.
- Granting broad production access and never reviewing it.

Exceptions

Any exception to these standards requires written approval from the Security team, a documented compensating control, and a review date.

Related documents

This document supersedes the older Password Policy where they conflict. See the API Authentication Guide for secret handling and the Data Retention Policy for how long data is kept.

Third-party and vendor security

Our security is only as strong as the vendors we rely on. Before integrating a third-party service that will handle company or customer data, assess its

security posture and limit what it can access.

- Review the vendor's security documentation and certifications before integrating.
- Grant the vendor the least access necessary and review it periodically.
- Prefer vendors that support modern authentication and encryption.
- Have a plan to revoke access and export or delete data if the relationship ends.

Record each vendor that handles sensitive data, what it can access, and who owns the relationship, so the list can be reviewed as part of regular security audits.